

REPORT DI SIMULAZIONE

CAMPAGNA DI PHISHING

INTRODUZIONE

OBIETTIVO: Creare una simulazione di un'e-mail di phishing utilizzando **LLM**.

1. CREARE UNO SCENARIO:

- Pensare a un contesto **realistico** in cui un'e-mail di phishing potrebbe essere inviata. Può essere una notifica bancaria, un'e-mail di un fornitore di servizi, un messaggio di un collega, ecc.
- Definire chiaramente l'obiettivo del phishing (ad esempio, ottenere credenziali di accesso, informazioni personali, dati finanziari, ecc.).

2. SCRIVERE L'E-MAIL DI PHISHING:

- Utilizzate un LLM per generare il contenuto dell'e-mail.
- Spiegate l'adversarial AI che avete utilizzato nel prompt **dell'LLM**.
- Assicuratevi che l'e-mail sia convincente, ma anche che contenga gli elementi tipici delle e-mail di phishing (ad esempio, richieste urgenti, link sospetti, postulati di cialdini).

3. SPIEGARE LO SCENARIO:

- Descrivere lo scenario che avete creato.
- Spiegare perché l'e-mail potrebbe sembrare credibile alla vittima.
- Evidenziate gli elementi dell'e-mail che dovrebbero far scattare un campanello d'allarme sulla sua autenticità

SCENARIO

CONTESTO

Lo scenario si basa su un attacco B2B tra due aziende con una relazione commerciale consolidata: "**MVLiving S.r.l**" e il suo cliente abituale, "**Fichera Infissi**".

Raccolta informazioni tramite OSINT

Prima di costruire l'attacco, ho condotto una fase di ricognizione sfruttando tecniche di **OSINT (Open Source Intelligence)**, ovvero la raccolta di informazioni da fonti pubblicamente accessibili. Le principali fonti utilizzate sono state:

- **LinkedIn:** per identificare nomi, ruoli e struttura organizzativa dei dipendenti di Fornitore S.r.l.
- **Sito web aziendale:** per raccogliere informazioni sull'attività, i contatti ufficiali e il formato delle e-mail aziendali.
- **Documenti pubblici:** eventuali comunicati, offerte o fatture disponibili online che rivelano il rapporto commerciale tra le due aziende.
- **Ricerca con LLM:** LLM con script su Python, basato su Gemini-Flash, programmato nelle esercitazioni precedenti, con system instruction di condurre OSINT sull'URL dato.

Grazie a questa fase, ho potuto identificare il nome di un dipendente reale dell'ufficio amministrativo, rendendo il messaggio immediatamente più credibile agli occhi della vittima. Sapere che l'azienda A si rifornisce dall'azienda B è già di per sé un'informazione sufficiente per costruire un pretesto convincente.

RISULTATO DELL'OSINT

L' OSINT condotto su Fichera Infissi ha condotto a questi risultati (oltre alle informazioni servite per il phishing, metterò tutte le informazioni raccolte con questo OSINT):

Report OSINT: ficherainfissi.it

Data: 2026-05-08T09:55:06.979557

Ecco il report OSINT basato sui dati forniti per il dominio **ficherainfissi.it**.

1. RIEPILOGO

Il dominio **ficherainfissi.it** è associato a un'attività commerciale (presumibilmente nel settore infissi) con sede ad Augusta (SR), intestata a **Gioseppe Fichera**. Il dominio, creato originariamente nel febbraio 2018, risulta attivo e recentemente aggiornato (novembre 2025). La gestione tecnica e i nameserver sono affidati a un provider terzo (soluzioneglobale.net), mentre il registrar è Aruba S.p.A.

2. INFRASTRUTTURA

- * **Indirizzo IP (Record A):** `149.255.58.144`.
- * **Gestione DNS (Nameservers):** Il dominio utilizza i server di `soluzioneglobale.net` (`ns.soluzioneglobale.net`, `ns2.soluzioneglobale.net`).
- * **Servizi Email:**
 - * **MX:** Il record punta direttamente al dominio stesso (`ficherainfissi.it`).
 - * **SPF (Sender Policy Framework):** Configurato per autorizzare l'invio da `149.255.58.144`, `149.255.62.163`, `149.255.58.2` e tramite il servizio esterno `relay.thundermail.uk`.
- * **Registrar:** Aruba S.p.A.
- * **Record CNAME:** Non disponibile.

3. RISCHI

- * **Esposizione Dati Personali:** Il record WHOIS espone pubblicamente nome, cognome e indirizzo fisico completo del registrante. Questo aumenta il rischio di ingegneria sociale o attività di marketing non richieste.
- * **Configurazione SPF Permissiva:** Il record SPF termina con `~all` (SoftFail). Questo indica ai server riceventi di accettare le email anche se non provengono dai server autorizzati, sebbene vengano contrassegnate come sospette. È una configurazione meno sicura rispetto a `-all` (Fail).
- * **DNSSEC non attivo:** Sebbene il registrar supporti DNSSEC, il campo "Signed" nel WHOIS indica "no", rendendo il dominio potenzialmente vulnerabile ad attacchi di DNS spoofing.
- * **Configurazione MX:** Il record MX che punta direttamente al record A del dominio (senza un host dedicato come `mail.ficherainfissi.it`) potrebbe indicare una configurazione server semplificata.

4. RACCOMANDAZIONI

- * **Sicurezza Email:** Verificare la presenza di record **DKIM** e **DMARC** (non presenti nei dati forniti) per prevenire attacchi di phishing e spoofing a nome del dominio.
- * **Hardening SPF:** Valutare il passaggio da `~all` a `-all` dopo aver confermato che tutti i servizi di invio legittimi siano stati censiti nel record.
- * **Privacy:** Valutare l'attivazione di un servizio di protezione della privacy WHOIS, se consentito per questa tipologia di registrazione, per oscurare l'indirizzo fisico e il nome del titolare.
- * **Verifica Infrastruttura:** Approfondire l'analisi su `soluzioneglobale.net` per comprendere il livello di sicurezza del provider che gestisce i nameserver.



Dopo aver cercato il sito, sono andato nei contatti social per verificare le varie collaborazioni.



Uno dei post menzionava la **collaborazione** con MVLiving, da qui l'idea di un attacco B2B.

OBIETTIVO DEL PHISHING

Convincere l'ufficio amministrativo di Fichera Infissi ad effettuare un bonifico verso un conto bancario fraudolento, presentandolo come un semplice aggiornamento delle coordinate bancarie del fornitore. Questo tipo di attacco viene classificato come **BEC (Business E-mail Compromise)**.

E-MAIL E TECNICHE UTILIZZATE

Per rendere l'e-mail indistinguibile da una comunicazione autentica, nel prompt dell'LLM sono state applicate le seguenti **tecniche di Adversarial AI**:

PERFEZIONAMENTO DEL LINGUAGGIO

Il modello è stato istruito a produrre un testo formale, privo di errori grammaticali o sintattici. Gli errori di scrittura erano un tempo il principale indicatore di phishing; oggi, grazie agli **LLM**, questo segnale è **praticamente scomparso**.

STYLE MIMICKING

Il modello ha replicato il **tono** tipico delle **comunicazioni amministrative** formali **italiane**, utilizzando espressioni come "**Certi della vostra collaborazione**" o "**restiamo a disposizione per chiarimenti**", frasi che chiunque lavori in un ufficio riconosce come normali.

IMPERSONIFICAZIONE CREDIBILE

Il nome del mittente è stato ricavato da un profilo LinkedIn pubblico di un dipendente reale del fornitore, rendendo il messaggio ancora più difficile da smascherare a prima vista.

E-MAIL DI PHISHING GENERATA

Da: amministrazione@mvliving.net

A: ficherainfissi@gmail.it

Oggetto: URGENTE: Aggiornamento coordinate bancarie per fatturazione, MVLiving S.r.l

Gentile Ufficio Amministrazione di Fichera Infissi,

Vi informiamo che, a seguito di una ristrutturazione interna dei nostri sistemi gestionali, le coordinate bancarie per il saldo delle prossime forniture hanno subito una variazione. Al fine di evitare ritardi nelle spedizioni programmate per la settimana entrante, Vi preghiamo di prendere visione del documento allegato, contenente il nuovo IBAN aggiornato e la relativa procedura di registrazione.

Vi ricordiamo che i pagamenti effettuati verso le vecchie coordinate non potranno essere elaborati dopo il **15 del mese corrente**.

Per qualsiasi chiarimento, il nostro ufficio rimane a completa disposizione.

Certi della vostra consueta collaborazione, porgiamo distinti saluti.

Maurizio Galeo

Ufficio Logistica e Amministrazione, MVLiving S.r.l

[Scarica il documento aggiornato](#)

PRINCIPI DI CIALDINI APPLICATI

- **Autorità:** Il mittente si presenta come dipendente ufficiale dell'ufficio amministrativo, con nome reale, ruolo e recapito telefonico.
- **Scarsità / Urgenza:** Viene fissata una scadenza esplicita ("entro il 15 del mese") per spingere all'azione immediata senza riflettere troppo.
- **Impegno e Coerenza:** Il messaggio si inserisce in una relazione commerciale già esistente, rendendo la richiesta contestualmente plausibile.
- **Reciprocità:** Il tono disponibile e collaborativo crea un senso implicito di obbligo verso il fornitore.

PERCHÉ L'EMAIL POTREBBE SEMBRARE CREDIBILE

L'e-mail potrebbe essere reale per i seguenti principi:

- Il **nome del mittente** corrisponde a un dipendente reale, facilmente rintracciabile su LinkedIn.
- Il **linguaggio** è formale, corretto e del tutto coerente con le comunicazioni amministrative reali.
- La **richiesta in sé**, ovvero un aggiornamento IBAN, è un'operazione ordinaria nel contesto B2B e non desta sospetti di per sé.
- La **scadenza temporale** crea urgenza e riduce il tempo dedicato alla verifica.

CAMPANELLI D'ALLARME

- **Dominio e-mail anomalo:** Il mittente usa mvliving.net al posto dell'e-mail ufficiale, una differenza minima ma significativa.
- **Cambio coordinate bancarie via e-mail:** Qualsiasi modifica di dati finanziari comunicata solo per e-mail va sempre verificata tramite un canale alternativo.
- **Allegato non atteso:** Il documento non è stato preannunciato da alcuna comunicazione precedente.
- **Urgenza artificiale:** La pressione della scadenza è progettata per far agire in fretta, senza pensare.
- **Nessuna conferma out-of-band:** Manca una telefonata di conferma su un numero ufficiale e verificato.

CONCLUSIONE

Questo esercizio ha messo in evidenza quanto sia diventato semplice, con gli strumenti disponibili oggi, costruire un'e-mail di phishing praticamente indistinguibile da una comunicazione reale. L'Adversarial AI elimina gli errori, replica lo stile e personalizza il messaggio, tutto quello che una volta richiedeva ore di lavoro manuale.

La cosa che mi ha colpito di più è che il punto debole non è tecnologico: firewall e filtri antispam possono fare solo una parte del lavoro. Il vero bersaglio è sempre la persona. Un dipendente stanco, di fretta, che riceve un'e-mail apparentemente normale da un fornitore che conosce, ha tutte le probabilità di non accorgersi di nulla.

Per questo la formazione è fondamentale quanto qualsiasi strumento tecnico, forse di più. Riconoscere l'urgenza artificiale, verificare sempre un secondo canale prima di toccare dati finanziari e non fidarsi ciecamente di un nome familiare sono abitudini semplici, ma che possono fare la differenza tra un bonifico legittimo e una truffa da centinaia di migliaia di euro.